

Network Security - Background, Local Area Network Attacks

**CSCI 4130: Introduction to Computer
Security**

Prof. Wei Meng

<https://course.cse.cuhk.edu.hk/~csci4130/>

Background

The Network Protocols

- Set of protocols used to transport data between nodes of a network
- TCP/IP Protocol Suite
- Link protocols
- Internet protocols
- Transport protocols
- Application protocols

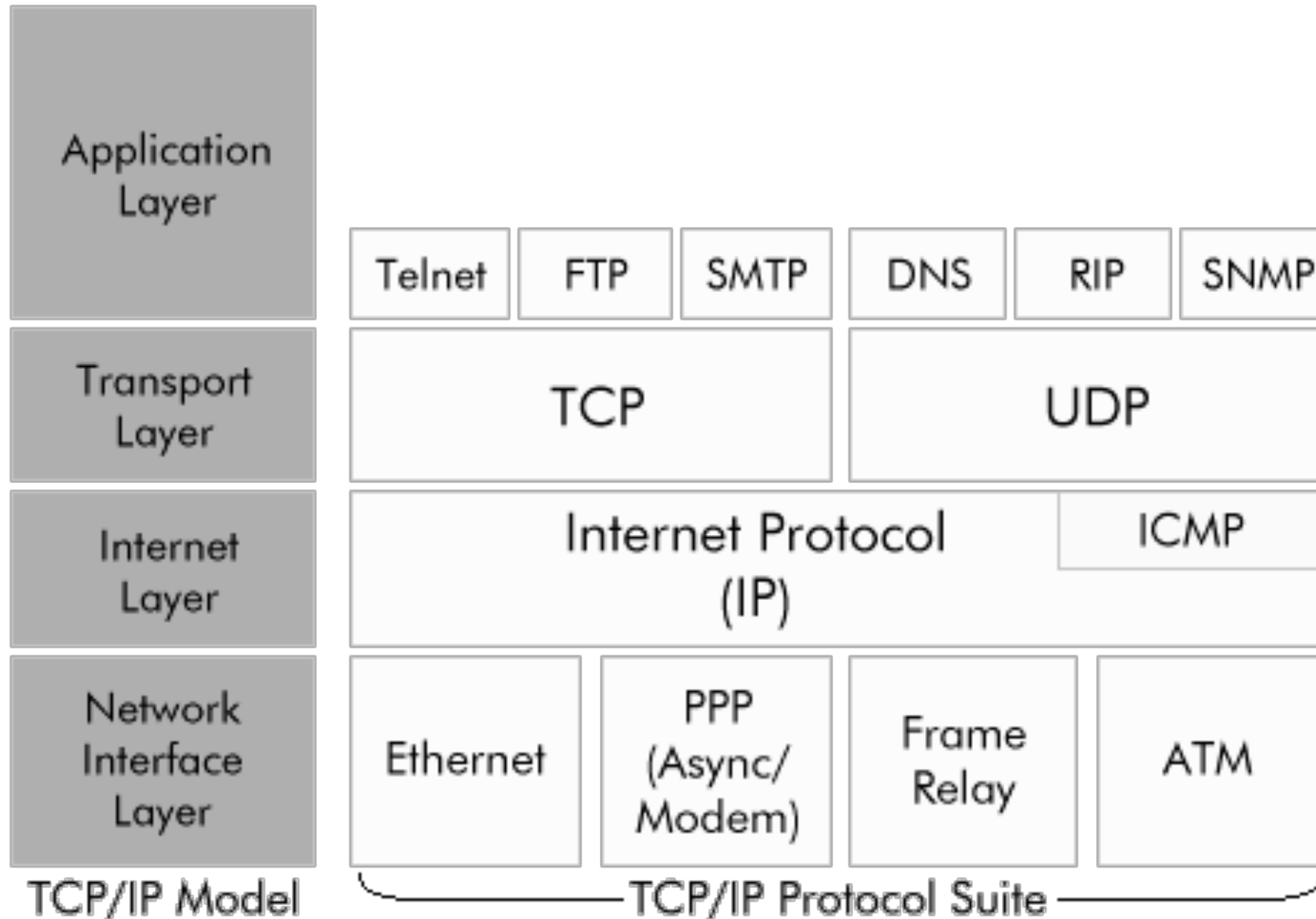
The Network Protocols (Cont.)

- A **protocol** is an agreement on how to communicate or to exchange data
- It defines the **syntax** and **semantics** of communication
 - In what format shall the message be structured?
 - In which order the messages shall be sent?
 - What actions need to be taken when receiving/missing a message?
- Example: Eating at a restaurant
 - Wait to be seated, receive the menu, order food, wait for the food, eat, pay the check

Layering

- The networking stack is built on top of several protocols at different **layers**
- Layering allows **modularization**, which simplifies the designs of protocols for different tasks
 - Different layers just agree on the interface to exchange messages
 - Implementation of each layer is independent of that of other layers
 - Change of implementation of a layer's service is transparent to rest of the system

TCP/IP Layering



TCP/IP Stack

- Physical: Bits “on the wire”
- Link: Data transfer between neighboring network nodes
 - PPP, Ethernet
- Transport: Process to process data transfer
 - TCP, UDP
- Network: Routing of datagrams from source to destination
 - IP
- Application: Supporting network applications
 - FTP, SMTP, HTTP

Internet Protocol

- The IP protocol is used to provide inter-connection of different networks
 - A glue of the Internet
- It provides a **connectionless, unreliable, best-effort datagram** delivery service
 - Delivery, integrity, ordering, non-duplication, and bandwidth are all not guaranteed
- IP datagrams (packets) can be exchanged between any two nodes on the Internet
- IP relies on a number of different lower-level layer protocols

IP Address

- Each network interface has one unique IP address which is globally addressable
- IPv4 addresses are composed of 4-byte values, represented in dotted-decimal notation
 - 127.0.0.1

IP Datagram

0	4	8	12	16	20	24	28	31
Version	HL	Type of Service	Total length					
Identifier			Flags	Fragment offset				
Time to live		Protocol		Header checksum				
Source address								
Destination address								
Options						Padding		
Data								

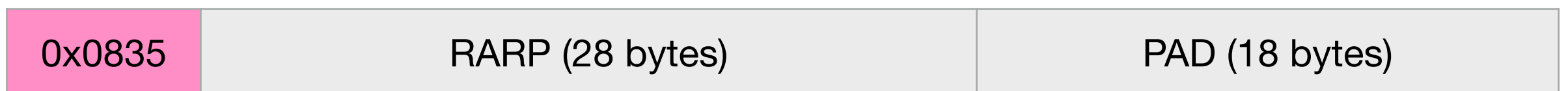
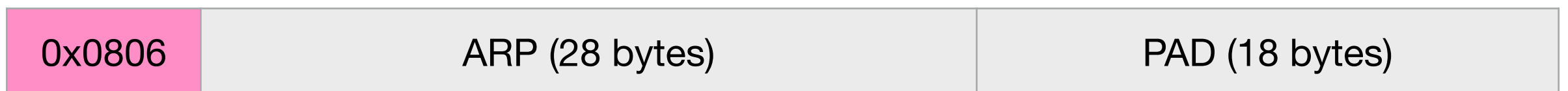
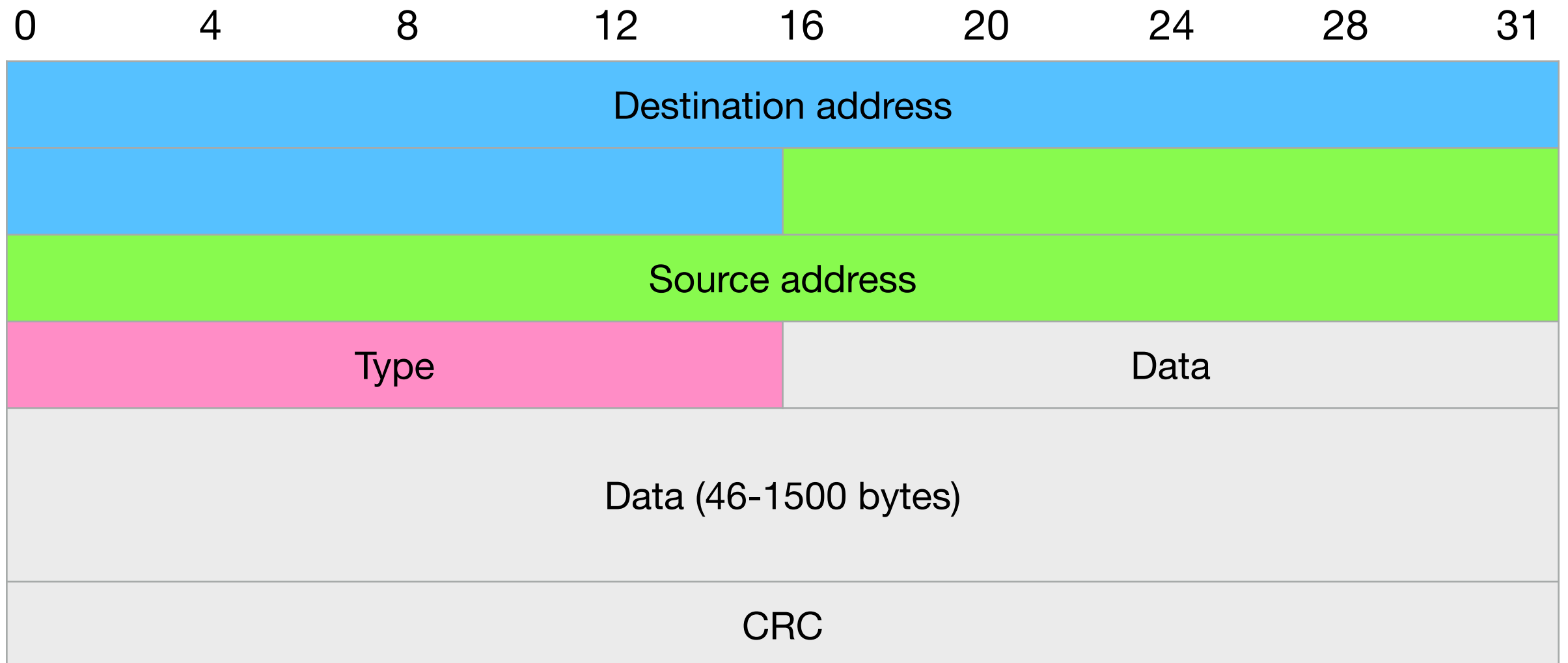
IP Datagram Delivery

- If two hosts are in the same physical network, the IP datagram is encapsulated in a lower level protocol and delivered directly
 - Example: An IP datagram encapsulated in an Ethernet packet
- If two hosts are in separate physical networks, the IP datagram is passed through devices of intermediate networks
 - Inter-network communications: routers
 - Intra-network communications: switches

Ethernet

- A widely used link-layer protocol
- Type: 2 bytes
 - IP, ARP, RARP
- Data
 - Min 46 bytes
 - Max 1500 bytes
- CRC: Cyclic Redundancy Check, 4 bytes

Ethernet Frame



Switches

- Switches are widely used to connect machines in a LAN
 - Store and forward Ethernet frames
 - Examine incoming frame's MAC address, **selectively** forward frame to one-or-more outgoing links
 - Self-learning mappings of ports and MAC addresses, plug and play
- Switching: Multiple packets can be switched simultaneously
- Switches maintain a table with MAC address/port mappings
- Switches learn the mappings from incoming frames

Local Area Network Attacks

Local Area Network Attacks

- Goals:
 - Impersonation of a host
 - Denial of service
 - Access to information
 - Tampering with delivery mechanisms
- Sniffing
- Spoofing
- Hijacking

Network Sniffing

- Sniffing (or eavesdropping) refers to the activity that gathers traffic from the local network
 - Put interface in **promiscuous mode**, to listen all transmissions even destination address is not mine
 - Can see **anything** - all data from link layer to application layer
 - If switched Ethernet is used, then the switch must be “convinced” that a copy of the traffic needs to be sent to the port of the sniffing host
- The technique is the basis of many attacks

Why Sniffing?

- Many protocols (FTP, POP, HTTP, IMAP) transfer data (e.g., authentication information) in the clear
- By sniffing, it is possible to collect credentials, emails, files, etc.
- Sniffing is also used by administrators to monitor network behavior

Sniffing Tools

- Tools to collect, analyze and reply traffic
- Routinely used for traffic analysis and troubleshooting
- Command-line tools
 - tcpdump: collects traffic
 - tcpflow: reassembles TCP flows for analysis
 - tcpreplay: re-send recorded traffic
- GUI tools
 - Wireshark

Detecting Sniffers

- Sniffers are typically passive programs
- They put the network interface in promiscuous mode and listen for traffic
- They can be detected by programs that provide information on the status of a network interface
- However, a kernel-level rootlet can easily hide the presence of a sniffer

Address Resolution Protocol

- A host usually has two addresses
 - Hardware address: link-layer address
 - IP address: network-layer address
- How does host A tell the MAC address of host B with its IP address?
- Address Resolution Protocol
 - It allows a host to map the IP address to the link-layer address associated with the peer's hardware interface to be used in direct delivery
 - ARP messages are encapsulated in the underlying link-level protocol

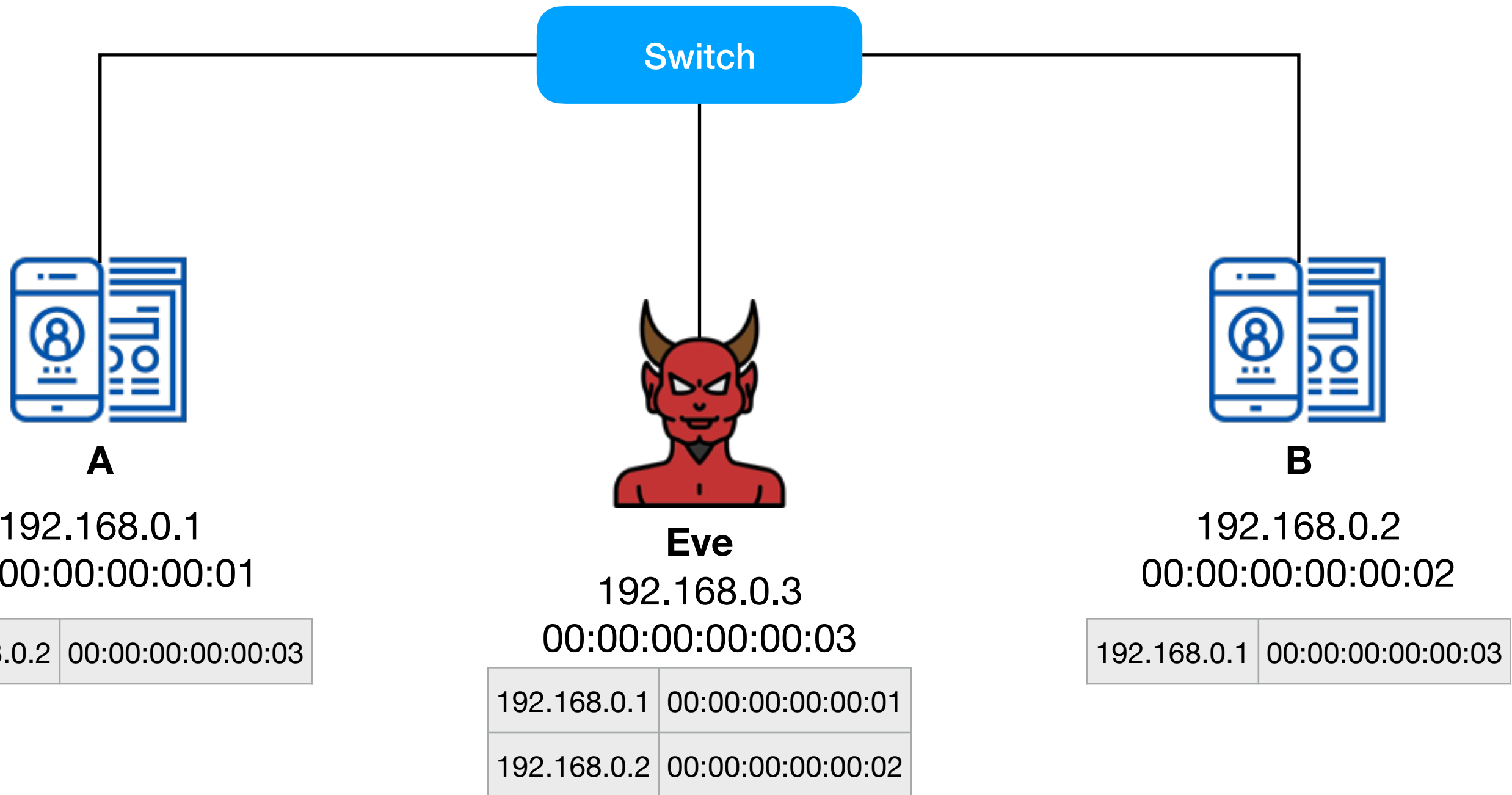
Address Resolution Protocol (Cont.)

- Each node maintains an ARP table that stores IP/hardware address mappings
- Host A wants to know the hardware address associated with the IP address of host B
- Host A broadcasts a message to all the hosts on the same local physical link
- Host B answers with a message including its link-level address
- Host A catches the answer in the ARP table

ARP Spoofing

- Goal: sniff all traffic between two hosts in a switched environment
- The attack leverages the **stateless** nature of the ARP protocol
 - Replies without a request will be accepted
- Example:
 - The attacker host sends spoofed ARP messages (request or reply) to the two victim hosts, poisoning their cache
 - The victim host sends their IP packets to the attacker host
 - The attacker host acts as a router

ARP Spoofing Example



ARP Spoofing Defenses

- Static ARP entries
 - The ARP cache can be configured to ignore dynamic updates
 - Difficult to manage in large deployments
- Cache poisoning resistance
 - Ignore unsolicited ARP replies (still vulnerable to hijacking)
 - Update on timeout (limited usefulness)
- Monitor changes (e.g., arpwatch)
 - Listen for ARP packets on a local Ethernet interface
 - Keep track for Ethernet/IP address pairs
 - Report suspicious activity and changes in mapping

Hijacking

- Sniffing and spoofing are the basis for hijacking
- The attacker sniffs the network, waiting for a client request
- Races against legitimate hosts when producing a reply
- ARP-, UDP-, TCP-based hijacking attacks

Dynamic Host Configuration Protocol

- New host doesn't have an IP address
 - Doesn't know what **source** IP address to use
- Host doesn't know whom to ask for an IP address
 - Doesn't know what **destination** IP address to use
- DHCP is a protocol to dynamically allocate IP addresses to hosts of a network
 - Broadcast a server-discovery message (link layer)
 - Server sends a reply offering an address

DHCP (Cont.)

- The DHCP server not only allocates an IP address, but also provides information about
 - DNS server
 - Gateway
 - The first hop for all Internet traffic to remote hosts
 - Period of the lease
- Local attackers can receive the broadcast message, and send a forged reply to race the real DHCP server
 - The attacker can potentially control the DNS server and the gateway used by the victim

Rogue Gateway

- The gateway is the first hop for all Internet traffic of a host
- An attacker that has control of a gateway can
 - Sniff Internet traffic
 - Intercept traffic
 - Block traffic
 - Modify traffic

DHCP Hijacking

- Threats
 - Fake DNS server
 - Redirect any DNS lookups to a host controlled by the attacker
 - Fake gateway router
 - Intercept all Internet traffic of a victim
 - Relay and modify contents between host and remote machine
- Defense
 - Difficult, because of lack of a trust anchor

Broadcast Protocol Security

- Broadcast protocols are inherently at risk of local attackers
 - Attackers can sniff the victim's messages
 - Attackers can spoof the address
 - Attackers can hijack the communication
- The clients are particularly vulnerable at the initialization step
 - No trust can be built upon
 - Wiring trust vs. flexibility

Securing the LAN

- Doing nothing
 - Assume we can keep the attackers out of our LAN
 - This is how most LANs are operated today
- Smart switching and active monitoring
 - Do not broadcast all traffic (the Hubs do this)
 - Only forward Ethernet frames to corresponding port
 - Filter requests so they go to specific ports to limit other systems from listening
 - Filter replies to limit other systems from replying

Credits

- Some slides are based on the slides of Giovanni Vigna, Raluca Ada Popa and Nicholas Weaver